

Indicators of Compromise (IOCs)

👉 Definition:

IOCs are **clues or evidence** left behind by attackers that help SOC Analysts detect, investigate, and respond to security incidents.

They can be found in **emails, logs, malware, or network traffic**.

Types of IOCs & What to Extract

1. Email-based IOCs

- **Sender Email Address / Domain** → Often spoofed (e.g., ceo@microsoft.com)
- **Return-Path Address** → May differ from "From" field (sign of spoofing)
- **Email Header anomalies** → Received-SPF: fail, mismatched domains
- **Embedded Links (URLs)** → Malicious phishing sites
- **Attachments** → Suspicious files (.exe, .zip, .docm, .js)
- **Subject / Content** → Keywords (e.g., "urgent payment", "reset password")

2. File-based IOCs

- **File Name** → Unusual names (e.g., invoice123.pdf.exe)
- **File Hashes** →
 - MD5, SHA1, SHA256
 - Unique fingerprint of the file
- **File Size / Metadata** → Abnormal timestamps, hidden macros
- **Digital Signatures** → Missing or fake code signing certificates

3. Network-based IOCs

- **IP Addresses** → C2 servers, malicious hosts
- **Domains / Hostnames** → Used in phishing or malware communication
- **URLs** → Malicious download links
- **Ports & Protocols** → Odd behavior (e.g., SSH on non-standard port, beaconing traffic)
- **DNS Requests** → Queries to suspicious or newly registered domains

4. Host / Endpoint IOCs

- **Registry Changes** (Windows) → Persistence keys, startup modifications
- **Processes & Services** → Suspicious processes (e.g., powershell.exe with obfuscated commands)
- **Scheduled Tasks** → Backdoors that auto-run
- **New/Unknown Accounts** → Created for lateral movement
- **Logon Attempts** → Brute force, unusual login times

5. Behavioral IOCs (TTPs)

- **Unusual User Behavior** → Login from unusual geo-locations
- **Data Exfiltration** → Large outbound traffic at odd hours
- **Privilege Escalation Attempts** → Normal user executing admin tasks

How SOC Analyst Uses IOCs

- ✓ Feed IOCs into **SIEM tools** (Splunk, QRadar, Elastic) for correlation
- ✓ Share IOCs with **Threat Intelligence Platforms** (MISP, Anomali, OpenCTI)
- ✓ Create **block rules** on firewall, proxy, EDR, email gateway
- ✓ Use IOCs for **incident reporting & threat hunting**